

민감정보 파일 반출 탐지를 위한 AI 기반 Host DLP 시스템 설계 및 구현



202155550 박동화 hvva1816@gmail.com

202121161 김진우 a01047463862@gmail.com

202155579 이상호 ttt1253@naver.com

지도교수 최윤희

목 차

1. 서론	1
1.1. 연구 배경 및 필요성	1
1.2. 문제 정의	2
1.3. 연구 목표	3
1.4. 연구의 주요 산출물과 기여	3
1.5. 연구 범위와 해석 기준	4
2. 연구 배경	5
2.1. Host 기반 Data Loss Prevention	5
2.2. 민감정보 반출 채널	5
2.3. 정규식과 문맥 분석의 결합	5
2.4. 중앙 로그와 대시보드	6
2.5. 본 과제의 설계 특징	6
3. 연구 내용	7
3.1. 전체 시스템 아키텍처	7
3.2. Host Agent 설계 및 구현	9
3.2.1. 공통 분석 파이프라인	9
3.2.2. 파일 텍스트 추출	10
3.2.3. 채널별 동작	10
3.2.4. 채널별 조치와 로컬 기록	11
3.3. AI Model Server 설계 및 구현	12
3.3.1. 분류 모델	12
3.3.2. 학습 및 검증 데이터 구성	12
3.3.3. 추론 API	14
3.4. Web Dashboard 설계 및 구현	15
3.4.1. 서버와 로그 저장	15
3.4.2. 대시보드와 검색	17
3.4.3. 준실시간 위험 알림	17
3.4.4. 접근 제어	20
3.5. 구성 요소 간 API와 데이터 흐름	20
3.5.1. 이벤트 순서	20

3.5.2.	Host에서 Web으로 보내는 로그	21
3.6.	보안 및 장애 대응	23
4.	구현 결과 및 검증	25
4.1.	검증 체계	25
4.2.	기능 자동화 검증	25
4.3.	성능 벤치마크 결과	26
4.3.1.	테스트 환경	26
4.3.2.	테스트 측정 방법	27
4.3.3.	파이프라인 구간 정의	27
4.3.4.	채널별 성능 측정 결과	27
4.3.5.	종합 분석	29
4.3.6.	결론	29
4.4.	AI 모델 성능 및 강건성 평가	30
4.4.1.	Threshold 재검증	30
4.4.2.	독립 홀드아웃 평가	31
4.4.3.	변형 표현 강건성 평가	31
4.4.4.	응답 지연시간	32
4.5.	Web 기능 검증 결과	32
4.6.	시나리오별 구현 및 검증 결과	32
4.7.	통합 검증 범위와 확장 항목	33
5.	결론 및 향후 연구 방향	35
5.1.	연구 결과 요약	35
5.2.	연구 성과	35
5.3.	향후 확장 방향	36
6.	구성원별 역할 및 개발 일정	37
6.1.	역할 분담	37
6.2.	개발 일정 및 주요 산출물	37
7.	참고문헌	39

1. 서론

1.1. 연구 배경 및 필요성

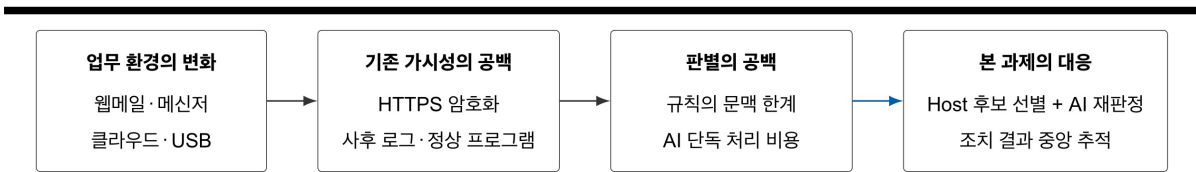
현대의 업무는 하나의 폐쇄된 사내 프로그램 안에서 끝나지 않는다. 문서는 웹메일로 전송되고, 협업 메시지의 입력창에 붙여넣어지며, 클라우드 저장소와 이동식 저장장치로 복사된다. 이 흐름은 업무 효율을 높이지만 주민등록번호와 계좌번호 같은 개인정보뿐 아니라 계약 단가, 인사 계획, 연구개발 자료처럼 형식이 일정하지 않은 업무 기밀이 외부로 이동할 수 있는 접점도 동시에 늘린다. 특히 정상 권한을 가진 사용자가 Chrome, Outlook, 파일 탐색기와 같은 정상 프로그램을 이용하는 경우에는 악성코드 탐지만으로 행위의 위험성을 판별하기 어렵다. 악의적인 내부자뿐 아니라 수신자 선택 오류, 잘못된 첨부, 개인 USB로의 임시 복사와 같은 실수도 같은 결과를 만들 수 있다.

본 과제를 시작한 직접적인 문제의식은 “전송된 뒤에 흔적을 찾는 것만으로 실제 유출을 막을 수 있는가”라는 질문이었다. 네트워크 구간의 HTTPS/TLS 암호화는 전송 내용을 보호하지만, 조직의 보안 관리자가 패킷만 보고 파일 내부를 판단하기 어렵게 한다. 운영체제 이벤트나 감사 로그는 사건 조사에는 유용하나, 기록 시점에는 이미 복사나 전송이 끝났을 수 있다. 반면 단말에서는 암호화되기 전의 텍스트와 파일, 사용 프로그램, 목적 채널을 함께 관찰할 수 있다. 따라서 반출 동작과 가까운 Host에서 후보를 감지하고, 판정과 조치 결과를 중앙에서 추적하는 구조가 필요하다고 보았다.

내용 판별에도 상반된 문제가 있다. 정규식은 주민등록번호나 전화번호처럼 구조가 고정된 정보를 빠르게 찾지만, 같은 숫자 형식이 예시인지 실제 개인정보인지 알지 못한다. 또한 “다음 분기 인수 제안 가격”처럼 고정 패턴이 없는 문장의 기밀성은 찾기 어렵다. 문맥 모델은 형식 기반 판별의 범위를 넓힐 수 있지만 모든 문서와 입력을 원격 모델로 보내면 지연, 자원 사용, 원문 노출 범위가 커진다. 이에 본 연구는 Host의 정규식으로 분석 후보를 줄이고 KoELECTRA 기반 모델로 후보 문맥을 재판정하는 2단계 구조를 선택하였다. 마지막으로 같은 사건의 탐지 근거, AI 점수, 판정 사유와 Host가 기록한 조치 코드를 Web 대시보드에 모아 보안 관리자가 결과를 설명하고 후속 조치를 결정할 수 있도록 하였다.

본 과제는 AI 분류뿐 아니라 운영체제 조치, 모델 서빙, API 계약, 데이터베이스와 사용자 화면을 하나의 사건 단위로 연결하는 종합 시스템을 대상으로 한다. 한 구성 요소가 좋은 결과를 내더라도 이벤트 식별자가 달라지거나 채널명이 어긋나면 중앙 기록을 신뢰할 수 없다. 모델이 block을 반환해도 USB 파일 삭제나 HTTP 차단 응답이 실제로 수행되지 않았다면 “차단됨”으로 표시해서는 안 된다. 본 과제는 이러한 경계 조건을 다루는 프로토타입의 구성 요소와 계약을 구현하고, 구현된 범위와 실제 장비에서 추가 확인할 범위를 구분하는 데 초점을 두었다.

앞서 설명한 문제와 설계 대응의 관계를 그림 1.1에 요약하였다.



[그림 1.1] 현실의 반출 문제에서 본 과제의 설계로 이어지는 논리

1.2. 문제 정의

본 과제의 보호 대상은 Host에서 다루는 텍스트 기반 개인정보와 업무 기밀이며, 위협 사건은 사용자가 허용되지 않은 외부 경로로 이를 복사·첨부·업로드하려는 동작으로 정의한다. 사용자 행위의 악의성 자체를 추론하는 대신, 보호 대상의 포함 가능성과 실제 반출 채널 및 조치 결과를 판별·기록한다. 랜섬웨어 탐지, 네트워크 침입 탐지, 이미지 OCR과 조직 전체 정책 관리 플랫폼은 본 과제의 1차 범위가 아니다.

해결해야 할 시스템 문제는 다음과 같이 정리하였다.

1. Windows 단말의 클립보드, 웹메일·클라우드 업로드와 USB 복사 경로에서 분석 대상 이벤트를 수집할 수 있어야 한다.
2. 파일과 입력 내용에서 텍스트를 추출하고 정규식으로 민감정보 후보를 선별한 뒤, 문맥 분석 결과를 allow, review, block으로 구분해야 한다.
3. AI 판정과 실제 운영체제·응용프로그램 조치를 분리하여, 차단 성공 여부를 과장하지 않는 최종 상태를 기록해야 한다.
4. Host, AI, Web이 같은 event_id, 채널명, 모델 버전과 점수 의미를 사용하도록 계약을 일치시켜야 한다.
5. 중앙 서버에서 사건을 중복 없이 저장하고 조건별 검색, 통계, 상세 근거와 준실시간 위협 알림을 제공해야 한다.

이를 연구 질문으로 바꾸면 다음 네 가지가 된다. 첫째, 서로 다른 Windows 채널을 하나의 분석·기록 흐름으로 어떻게 정규화할 것인가? 둘째, 규칙 기반 후보 선별과 문맥 모델 재판정을 어떻게 결합하고 모델 장애 시 업무 연속성을 어떻게 유지할 것인가? 셋째, AI의 판단과 실제 조치 결과를 어떤 증거로 연결할 것인가? 넷째, 코드·자동화 테스트·실장비 통합 검증을 어떻게 구분하여 결과의 신뢰 범위를 명확히 할 것인가? 이후의 설계와 검증은 이 질문에 답하는 순서로 구성하였다.

1.3. 연구 목표

최종 목표는 Windows Host Agent, AI Model Server, Web Dashboard를 동일 데이터 계약으로 연동할 수 있는 Host DLP 프로토타입을 구현하고, 감지부터 중앙 표시까지의 계약을 재현 가능한 방법으로 검증하는 것이다. 세부 목표와 확인 기준은 표 1.1과 같다.

구분	목표	확인 기준
Host Agent	반출 채널 감시, 텍스트 추출, 규칙 후보 선별, AI 요청과 실제 조치	채널 코드·설정, Web 전송 계약 테스트, Windows 종단 간(end-to-end, E2E) 검증
AI Model	한국어 문맥 기반 이진 분류와 3단계 의사결정	데이터·학습 코드, API 계약, 독립 분포 외(Out-of-Distribution, OOD) 평가 산출물
Web	중앙 로그 수집, 조회, 통계, 상세 근거와 위험 알림	API·DB·화면 계약 자동화 테스트
통합	동일 사건의 감지-판정-조치-저장을 연결	동일 event_id와 모델·조치 증거, 실장비 E2E

[표 1.1] 연구 목표와 확인 기준

비기능 목표는 Agent CPU 5% 미만, 메모리 100MB 미만, AI F1 90% 이상과 Recall 우선, 대시보드 인증 및 HTTPS로 설정하였다. 자동화 시험과 실장비 측정을 구분하여 각 목표의 검증 결과와 확장 측정 범위를 제시한다.

1.4. 연구의 주요 산출물과 기여

주요 산출물은 다음 네 가지이다.

- 다중 채널 Host 처리 기반:** 클립보드, HTTPS Web Proxy 기반 웹메일·클라우드 업로드와 이동식 USB 복사를 규칙-AI 분석 흐름에 연결하였다. 현재 Host는 기록 대상인 block과 review를 각각 BLOCKED, WARNED로 변환하며, 정상 allow는 통과시키되 중앙 사건으로 저장하지 않는다.
- 한국어 문맥 재판정 파이프라인:** KoELECTRA 미세조정 코드, 균형 데이터, 3단계 임계값과 Colab 용 분석 API, 하드 테스트·임계값 분석 스크립트를 구성하였다.
- 중앙 관제 Web:** FastAPI와 SQLite로 중복 방지 로그 수집, 검색·페이지 조회, 최근 7일 집계, 상세 판정 근거, 위험 알림과 Agent 인증을 구현하였다.

-
4. **구성 요소 연동 계약:** Host, AI, Web 사이의 사건 식별자, 채널, 판정과 조치 상태를 연결하는 데이터 계약을 정리하고 API·화면과 payload 변환을 자동화 시험으로 확인하였다. Host-AI 인증과 일부 채널·조치 상태의 정합화는 운영 확장 항목으로 정리하였다.

1.5. 연구 범위와 해석 기준

검사 대상은 텍스트, DOCX, XLSX, PPTX, PDF 등 텍스트 추출이 가능한 자료이다. 본 연구의 1차 범위는 텍스트 기반 분석과 사용자 영역 조치이며, OCR, 이미지·도면 의미 분석, 커널 드라이버 서명·배포, 상용 DLP 수준의 중앙 정책 배포와 다중 조직 운영은 확장 범위로 둔다. Web 샘플 데이터와 화면은 기능 시연 자료로 구분한다. AI 성능 수치는 4.4절의 독립 홀드아웃 평가 범위에서 제시하고, 실제 기업 문서 기반 대규모 평가는 확장 검증 항목으로 구분한다.

2. 연구 배경

2.1. Host 기반 Data Loss Prevention

Data Loss Prevention(DLP)은 조직의 중요정보가 허용되지 않은 경로로 이동하는 것을 감지하고 통제하는 기술이다. Host 기반 방식은 사용자 단말에서 파일 접근, 복사, 붙여넣기, 메일 전송과 업로드를 관찰할 수 있어 실제 반출 시점에 가까운 정보를 얻을 수 있다. NIST SP 800-53 Rev. 5도 정보 흐름 통제와 시스템 모니터링을 주요 보안 통제로 제시한다 [4].

Host 방식에서는 감지 범위가 넓을수록 운영체제 권한, 응용프로그램 동작, 네트워크 설정의 영향을 많이 받는다. 예를 들어 USB 파일 복사는 커널 수준에서 쓰기 전 차단할 수도 있고, 사용자 영역에서 복사 완료를 감지한 뒤 파일을 제거할 수도 있다. 본 과제는 프로토타입 범위를 고려하여 가능한 경우 사용자 영역 방식과 응용프로그램 hooks를 사용하였다.

2.2. 민감정보 반출 채널

민감정보 반출은 하나의 프로그램에만 한정되지 않는다. 본 시스템이 대상으로 삼은 대표 채널은 다음과 같다.

- **클립보드**: 문서의 일부를 메신저나 외부 프로그램에 붙여넣는 경로
- **전자메일**: 외부 수신자에게 본문 또는 첨부파일을 전송하는 경로
- **웹 업로드**: 웹메일과 클라우드 드라이브로 파일을 업로드하는 경로
- **USB**: 이동식 저장장치에 파일을 복사하는 경로

채널마다 이벤트를 관찰하는 방법과 차단 시점이 다르다. 그러므로 공통 분석 파이프라인을 유지하되 실제 조치는 채널 모듈이 담당하는 구조가 필요하다.

2.3. 정규식과 문맥 분석의 결합

주민등록번호, 전화번호, 계좌번호처럼 구조가 일정한 정보는 정규식으로 빠르게 후보를 찾을 수 있다. 다만 형식만 일치한다고 해서 모두 실제 개인정보인 것은 아니며, 형식이 없는 업무상 기밀 문장은 정규식만으로 구분하기 어렵다.

본 시스템에서 클립보드, USB와 Web Proxy는 Host에서 정규식 기반 1차 탐지를 수행하고 후보가 있는 경우 실제 탐지 문맥과 메타데이터를 AI 서버로 전송한다. SMTP와 평문 HTTP 모듈도 코드에는 있으나 기본 설치·시연 범위에서는 비활성이다. AI 서버는 KoELECTRA 기반 이진 분류 점수를 계산한 후 두 개의 임계값을 이용하여 3단계 결정을 반환한다. BERT의 양방향 문맥 표현과 ELECTRA의 판별기 기반 사전학습, 한국어에 맞춘 KoELECTRA는 이 문맥 재판정 방식의 기술적 배경이 된다 [1, 2, 3].

현재 구현에서 AI 분석은 정규식이 적중한 후보에만 수행된다. 따라서 문맥 모델의 역할은 규칙 후보를 재판정하는 것이며, 정규식이 찾지 못한 민감 문장을 독립적으로 발견하는 구조는 아니다.

2.4. 중앙 로그와 대시보드

단말에서 차단이 수행되더라도 관리자가 사건을 확인할 수 없다면 정책 개선과 사후 분석이 어렵다. 중앙 Web 서버는 Host가 보낸 표준 로그를 SQLite에 저장하고, 기간·부서·사용자·Agent·채널·조치 조건으로 조회한다. 또한 최근 7일의 사건 수와 채널 분포를 시각화하고, 위험 이벤트를 주기적으로 조회하여 화면과 소리로 알린다.

2.5. 본 과제의 설계 특징

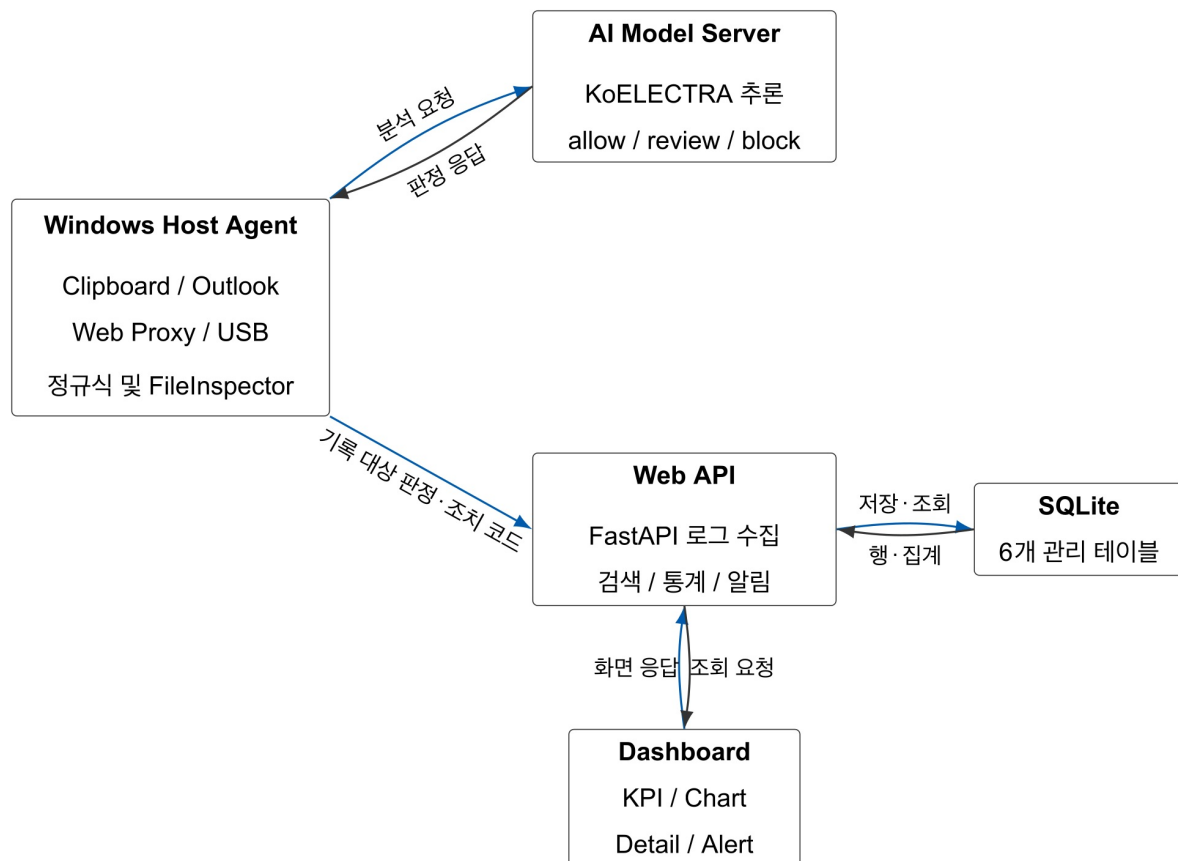
본 연구는 다중 채널 감지, 한국어 문맥 분석, 중앙 관제의 핵심 흐름을 분리된 세 구성 요소로 구현하고 API 계약으로 연결하는 데 초점을 둔다. 또한 판정 점수뿐 아니라 매칭 규칙, 판정 사유, 파일 정보, AI 서버가 보고한 추론 지연과 Host가 기록한 조치 코드를 함께 저장하여 결과를 설명할 수 있도록 설계하였다.

3. 연구 내용

이 장에서는 세 구성 요소의 최종 설계와 구현 범위를 설명하고, 검증 결과는 4장에서 제시한다.

3.1. 전체 시스템 아키텍처

시스템은 Windows Host Agent, AI Model Server, Web Dashboard의 세 영역으로 구성된다. Host Agent는 AI 서버를 직접 호출하여 판정을 받은 뒤, 기록 대상으로 선택된 사건의 AI 분석 결과와 정규화한 조치 코드를 Web 서버의 POST /api/v1/logs로 별도 전송한다. 최종 연동 구조에서 Web은 AI 판정을 생성하거나 AI Server를 중계하지 않고, Host가 전달한 결과를 검증·저장하여 검색·통계·상세 조회와 위험 알림으로 제공한다.



[그림 3.1] 전체 시스템 아키텍처

그림 3.1에 나타난 것처럼 분석 요청과 관제 로그는 서로 다른 경로로 전송된다. AI 서버는 Host 요청의 event_id를 그대로 반환한다. Host는 자신이 분석 요청에 부여한 payload.request_id를 Web 로그에도 사용하므로, 기록 대상으로 남는 정상 경로에서는 같은 사건 ID를 구성 요소 사이에서 추적할 수 있다.

분석과 관제 경로의 분리는 Web이 일시적으로 중단되어도 Host의 AI 판정과 채널 조치가 중앙 화면 때문에 지연되지 않게 하고, AI Server가 Web DB에 직접 의존하지 않도록 한다. Host는 AI·Web 서버 주소와

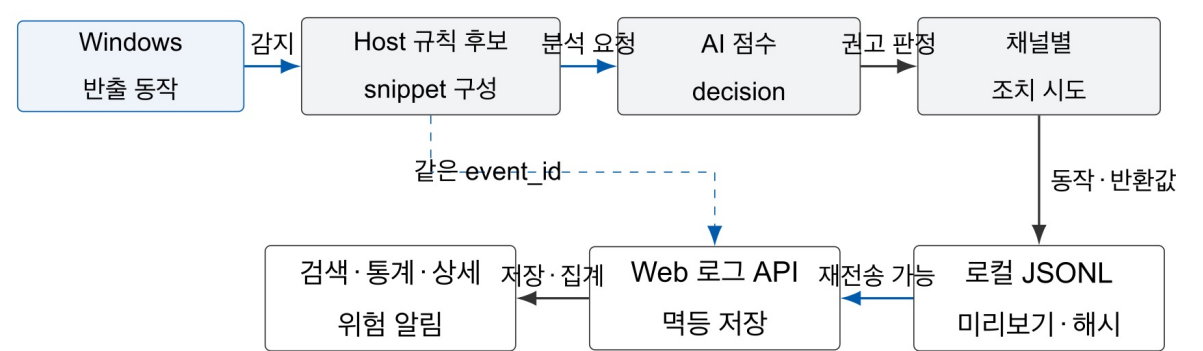
Web Agent Token을 설정하고 같은 사건을 양쪽 호출에서 연결한다. 현재 Host-AI 경로는 신뢰된 시연 환경을 전제로 하며, 별도 인증 토큰은 운영 확장 항목으로 둔다.

구성 요소별 책임과 신뢰 경계는 표 3.1에 구분하였다.

구성 요소	소유하는 책임	소유하지 않는 책임
Host Agent	Windows 행위 감지, 텍스트 추출, 규칙 후보, AI 호출, 채널별 조치 시도·기록, 로컬 증거와 Web 전송	모델 학습·임계값 산출, 중앙 DB 집계
AI Server	기본 입력 schema 검증, KoELECTRA 추론, 점수와 3단계 결정, 모델 버전·지연 응답	운영체제 차단 성공 판단, 중앙 사건 생성
Web API	Agent 인증, 로그 검증·먹등 저장, 조회·통계·알림	Host의 실제 차단 집행, 최종 연동 경로에서의 AI 판정 생성·모델 추론
Dashboard	저장된 사건의 검색·시각화·상세 근거·위험 알림	모든 반출 시도의 완전성 보증, 실시간 push 보장

[표 3.1] 구성 요소별 책임과 신뢰 경계

그림 3.2에 나타난 시스템 흐름은 판단을 만드는 **분석 경로**, 실제 사용자의 동작을 바꾸는 **조치 경로**, 나중에 사건을 재구성하는 **증거 경로**로 나눌 수 있다. 세 경로를 분리하면 “AI가 차단을 권고했다”와 “운영체제에서 실제로 차단됐다”를 같은 문장으로 오해하는 것을 줄일 수 있다.



[그림 3.2] 분석·조치·증거 경로의 분리

3.2. Host Agent 설계 및 구현

3.2.1. 공통 분석 파이프라인

모든 채널은 그림 3.3과 같이 다섯 단계로 구성된 공통 파이프라인을 공유한다.



[그림 3.3] Host Agent 공통 이벤트 처리 흐름

정규식 미적중 사건은 AI 경로에 진입하지 않고 즉시 통과된다. 정규식이 적중한 경우 채널별 방식으로 임시 차단한 뒤 ApiClient가 AI 서버(POST /api/v1/analyze)를 호출하고 판정 결과(block / review / allow)를 수신한다.

AI 서버 URL이 settings.yaml에 설정되지 않은 경우 mock 모드로 동작하며, 정규식 매칭 심각도(severity)를 기준으로 즉시 판정한다. Mock 모드의 detection_type은 RULE_BASED, 실제 서버 호출 시에는 HYBRID로 기록된다.

AI 서버가 타임아웃이나 통신 오류로 응답하지 못하면 analysis_failed=True, 점수 1.0, action=block으로 변환하여 Fail-Closed 정책을 유지한다. 이 경우 EventLogger는 대시보드 payload의 ai_score를 NULL로 기록하고, analysis_status는 FAILED로 전달한다.

판정 결과에 따른 채널별 동작과 중앙 기록 상태는 표 3.2와 같다.

조건	Host의 동작·반환값	대시보드 상태	해석
정규식 미적중 AI block	원래 동작 계속 클립보드: 억제 유지+팝업 / 웹메일·드라이브: HTTP 451 / USB: os.remove()+팝업	기록 없음 BLOCKED (analysis_ status=SUCCESS)	AI 경로 미진입, 일반 동작 action=blocked로 중앙 기록. 조치 물리적 성공은 별도 확인
AI review	클립보드: 억제 유지+팝업 / 웹메일·드라이브: HTTP 451 / USB: 파일 유지, 로그만 기록	WARNED	USB는 파일이 통과됨. 웹메일·드라이브는 review 도 차단
AI allow	클립보드: 복원 후 Ctrl+V 재발행 / 웹메일· 드라이브·USB: 통과	기록 없음	오탐 복구. 클립보드는 붙여넣기 자동 재발행
AI 장애/타임아웃	점수 1.0, action=block으로 채널별 차단 시도	BLOCKED (analysis_ status=FAILED, ai_score=NULL)	보수적 Fail-Closed 처리
채널 조치 예외	경로 로그만 기록	대체로 BLOCKED 유지	현재 구현은 조치 결과를 WARNED로 자동 정규화하지 않음

[표 3.2] AI 판정과 채널 조치 및 중앙 기록 상태 변환

AI 결과가 allow인 경우 EventLogger는 어떤 채널에서도 기록을 남기지 않는다. 따라서 중앙 데이터베이스는 모든 사용자 동작이 아닌 차단 또는 검토 판정 사건만을 나타낸다.

3.2.2. 파일 텍스트 추출

FileInspector는 파일 경로 또는 바이너리 바이트로부터 DLP 검사용 텍스트를 추출한다. 표 3.3에 지원 형식을 정리하였다.

분류	지원 확장자
텍스트·소스코드	.txt, .csv, .log, .xml, .json, .yaml, .md, .html, .py, .js, .ts, .jsx, .tsx, .java, .c, .cpp, .cs, .go, .rb, .php, .sql, .sh, .bat, .ps1, .env 등
MS Office	.docx, .xlsx, .xls, .pptx
PDF	.pdf (전체 페이지)
한글	.hwp, .hwpk (olefile 기반 부분 지원)
압축	.zip (내부 파일 최대 50개 재귀 검사)
기타 바이너리	UTF-8 / CP949 디코딩 시도. 디코딩 불가 시 None 반환

[표 3.3] FileInspector 지원 파일 형식

암호화 파일, 손상 파일, 지원 외 바이너리 형식 등 텍스트 추출이 불가능한 경우에는 None을 반환하고 debug 로그를 남긴다. 형식 판별은 확장자 기준이며, 확장자 위장 탐지는 운영 확장 범위로 구분한다.

ai_max_text_chars(기본값 0 = 무제한)가 설정된 경우 추출 텍스트를 해당 길이로 자른 뒤 AI 서버로 전달한다. Web Proxy는 추가로 _MAX_UPLOAD_EXTRACT_BYTES(2 MB) 및 _MAX_INSPECT_TEXT_CHARS(2 MB) 상한을 적용하여 대용량 파일 업로드 시 메모리 과점유 및 AI 타임아웃을 방지한다.

3.2.3. 채널별 동작

구현된 채널은 클립보드, 웹메일, 클라우드 드라이브, USB 총 4개이며, 모두 channel_policy.json에서 enabled: true로 활성화되어 있다.

클립보드는 WH_KEYBOARD_LL 키보드 훅으로 Ctrl+V 입력을 감지한다. 정규식이 적중하면 즉시 붙여넣기를 억제한 뒤 별도 스레드에서 AI 분석을 비동기로 수행한다. AI가 block 또는 review를 반환하면 억제를 유지하고 팝업으로 사용자에게 알린다. allow를 반환하면 클립보드를 복원하고 Ctrl+V를 재발행하여 오탐을 자동 복구한다.

웹메일과 클라우드 드라이브는 동일한 HTTPS MITM 프록시(포트 8082)를 통해 처리된다. 웹메일은 Gmail, 네이버 메일, Outlook.com 등 14개 도메인의 업로드 요청을 검사하고, 클라우드 드라이브는 Google Drive, MYBOX, OneDrive, Dropbox, Box의 업로드 경로 패턴으로 대상을 식별한다. 두 채널 모두 block과 review 판정 시 HTTP 451을 반환하여 브라우저 단에서 전송을 차단한다. 동작을 위해서는 setup_proxy.ps1 실행으로 CA 인증서 설치와 시스템 프록시 설정이 선행되어야 한다.

USB는 ReadDirectoryChangesW API로 이동식(REMOVABLE) 및 외장 고정(FIXED) 드라이브의 파일 변경을 감시한다. 설치 시 생성되는 internal_drives.json을 기준으로 내장 드라이브를 제외하며, 외장 SSD처럼 FIXED 타입으로 인식되는 장치도 감시 대상에 포함된다. AI가 block을 반환하면 os.remove()로 파일을 삭제하고 팝업을 표시한다. review 판정 시에는 파일을 유지하고 로그만 기록한다. 이 방식은 복사 완료 후 삭제하는 사후 차단(detect-and-remediate) 구조이므로 수 KB 이하 소형 파일은 삭제 전에 복사가 완료될 수 있으며, 완전한 사전 차단을 위해서는 커널 드라이버 방식이 필요하다.

3.2.4. 채널별 조치와 로컬 기록

차단 방법은 채널에 따라 다르다. 클립보드는 훅 반환값으로 붙여넣기를 억제하고, 웹메일·클라우드 드라이브는 HTTP 451 응답을 반환한다. USB는 os.remove()로 파일을 사후 삭제한다. USB 삭제 또는 Web Proxy 응답 전달이 완료되지 않은 경우에도 중앙 기록의 action_taken=BLOCKED 상태는 유지되므로, BLOCKED는 조치 시도를 나타내며 물리적 성공 여부는 실장비 검증에서 별도로 확인한다.

모든 탐지 이벤트는 로컬 JSONL 파일(logs/events.jsonl)에 우선 기록된다. 각 레코드에는 채널명, 조치 종류, 적중 규칙 목록, 원문 앞 120자(text_preview), 전체 원문의 SHA-256 해시(text_sha256), AI 신뢰도 점수, 전체 파이프라인 처리 시간이 포함된다. 파일 크기가 10 MB를 초과하면 날짜·시각 기준 파일명으로 자동 로테이션된다.

settings.yaml에서 send_immediately: true이고 dashboard_url이 설정된 경우, EventLogger는 기록 직후 별도 스레드에서 대시보드 API(POST /api/v1/logs)로 비동기 전송한다. 요청 헤더에는 X-Agent-Token과 X-Agent-ID가 포함된다. 네트워크 단절 등으로 전송이 완료되지 않은 이벤트는 flush_to_server()를 통해 로컬 JSONL에서 일괄 재전송할 수 있으며, 대시보드 서버는 event_id를 기준으로 중복을 제거한다. 이 이중 기록 구조를 통해 네트워크 단절 상황에서도 로컬에서 단일 사건을 보존한다.

3.3. AI Model Server 설계 및 구현

3.3.1. 분류 모델

AI Model Server는 ELECTRA와 한국어 사전학습 모델 KoELECTRA를 바탕으로 비기밀/기밀 이진 분류를 수행한다 [2, 3]. 여기서 기밀(1)은 법적 기밀 등급의 확정이 아니라 규칙 후보 문맥의 민감 가능성을 나타내는 모델 라벨이다. 현재 학습 코드의 주요 설정은 표 3.4에 정리하였다.

항목	설정값
기본 모델	monologg/koelectra-base-v3-discriminator
분류 클래스	비기밀(0), 기밀(1)
최대 입력 길이	128 token
데이터 분할	Train 80%, 평가 20% 계층 분할
난수 고정	seed 42
학습 반복	최대 8 epoch
Batch size	8
Learning rate	2×10^{-5}
Weight decay	0.01
조기 종료	평가 20%의 F1 기준, patience 3
모델 버전	koelectra-dlp-v7

[표 3.4] KoELECTRA 미세조정 설정

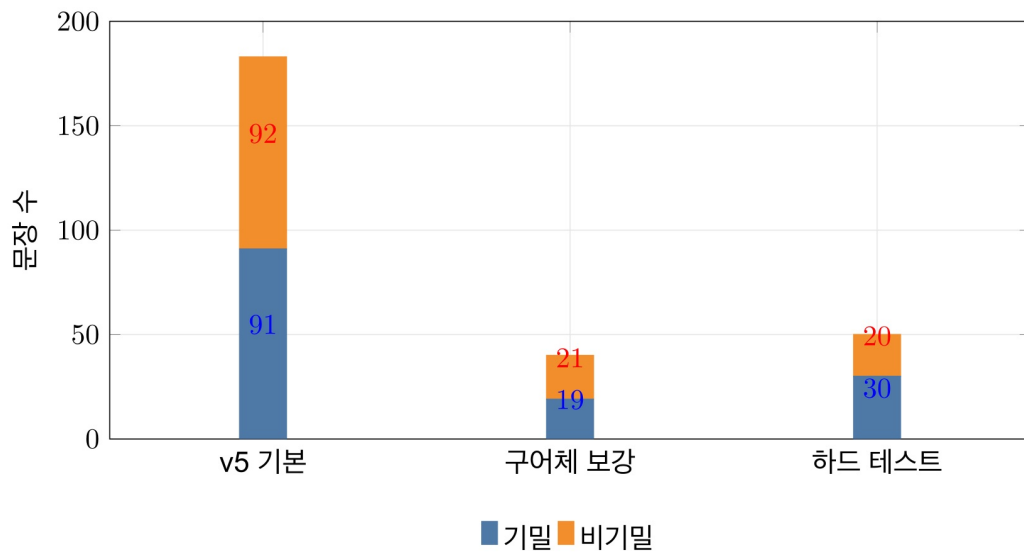
모델 출력의 민감 점수 p 는 다음 기준으로 최종 결정으로 변환된다.

$$\text{decision}(p) = \begin{cases} \text{allow}, & p < 0.20 \\ \text{review}, & 0.20 \leq p < 0.41 \\ \text{block}, & p \geq 0.41 \end{cases}$$

두 임계값을 사용하면 명확히 낮은 점수와 높은 점수 사이에 검토 구간을 둘 수 있다. 다만 임계값의 타당성은 최종 검증 데이터와 실제 업무 문서에 대한 Precision, Recall, F1을 함께 측정하여 다시 확인해야 한다.

3.3.2. 학습 및 검증 데이터 구성

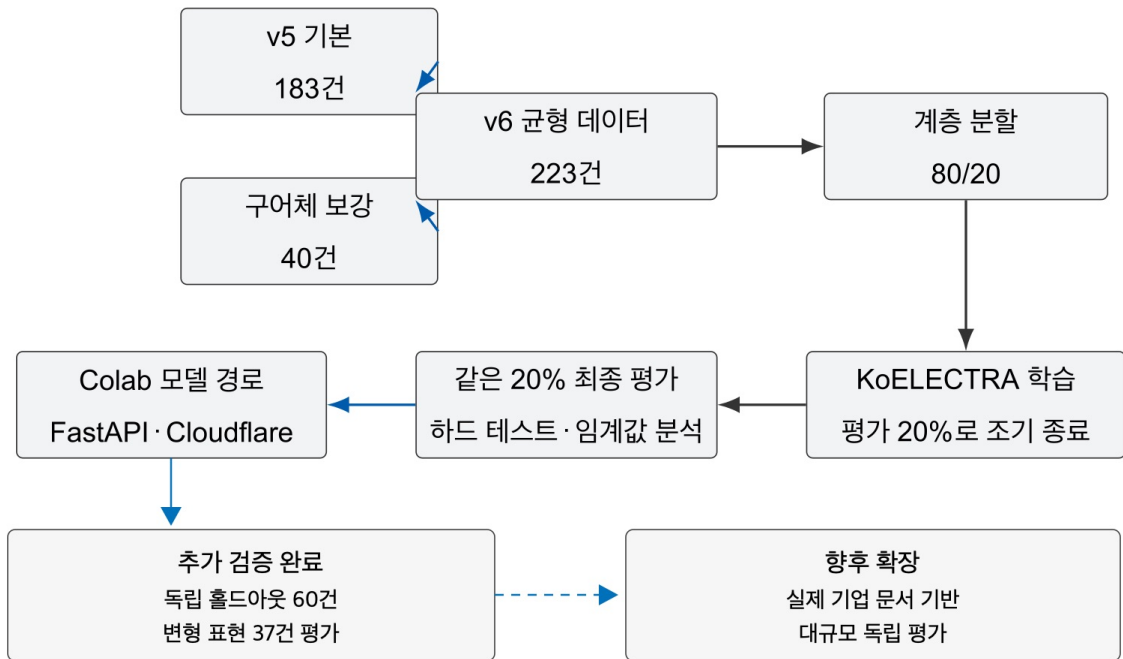
CSV 원본을 집계하면 v5 기본 데이터는 183건(기밀 91, 비기밀 92)이고, 구어체 보강 40건(기밀 19, 비기밀 21)을 합친 최종 v6는 223건(기밀 110, 비기밀 113)이다. 하드 테스트 50건(기밀 30, 비기밀 20)은 학습 데이터와 별도로 관리한다. 구성별 클래스 분포를 그림 3.4에 나타냈다.



[그림 3.4] v6 구성 데이터와 별도 하드 테스트의 문장 수

v5 기본 데이터와 구어체 보강 데이터는 두 클래스가 거의 균형을 이룬다. 두 데이터를 합친 v6는 총 223건이며, 하드 테스트 50건은 이에 중복 합산하지 않는다. v6는 평가에서 확인한 도메인 특성을 반영해 편향을 완화하도록 구성하였다. 같은 업무 도메인 안에 기밀·비기밀 문장을 함께 배치하여 “보안”, “재무” 같은 주제 단어 자체가 아니라 공개 범위와 업무 맥락을 학습하도록 의도하였다.

현재 학습·평가 흐름을 그림 3.5에 나타냈다. v7 스크립트는 v6 데이터를 계층화해 Train 80%와 평가 20%로 나눈다. 평가 20%는 매 epoch의 평가·조기 종료와 내부 지표 산출에 사용하며, 별도 하드 테스트는 임계값 검토에 활용한다. 독립 일반화 성능은 고정 임계값과 신규 홀드아웃을 사용해 4.4절에서 평가하였다. checkpoint·label mapping·번들 무결성 확인은 배포 재현성 확장 항목으로 둔다.



[그림 3.5] KoELECTRA 데이터 준비·학습·배포 절차와 검증 범위

v6의 무작위 분할은 내부 학습과 모델 선택에 활용하고, 신규 홀드아웃은 학습·임계값 선정과 분리하여 평가한다. 향후 부서·문서 유형·작성자 그룹 단위 분할, 정규화 중복 검사와 실제 기업 문서 기반 잠금 OOD 표본으로 데이터 대표성과 평가 범위를 확장한다. v7 모델의 정량 검증 결과는 4.4절에 제시한다.

3.3.3. 추론 API

AI Server의 핵심 인터페이스는 POST /api/v1/analyze이다. Host는 이벤트 식별자, 채널, 사용자, 매칭 패턴, 분석 문맥과 메타데이터를 전송한다. 서버는 결정값, 민감 점수, 모델 버전, 서버 내부 추론 지연과 판정 사유를 반환한다.

[코드 3.1] Host에서 AI Server로 보내는 요청 예시

```

{
  "event_id": "6a9be829-0000-4000-8000-000000000001",
  "channel": "drive_upload",
  "user_id": "demo-user",
  "matched_patterns": ["rrn"],
  "snippet": "[redacted synthetic sensitive context]",
  "metadata": {
    "app": "browser.exe",
    "severity_hint": "high"
  }
}

```

[코드 3.2] AI Server의 응답 예시

```
{
  "event_id": "6a9be829-0000-4000-8000-000000000001",
  "decision": "block",
  "confidence_score": 0.87,
  "model_version": "koelectra-dlp-v7",
  "latency_ms": 42.1,
  "reason": "synthetic sensitive context; block recommended"
}
```

위 예시의 snippet은 민감정보 보호를 위해 비식별 문자열로 표시하였다. 실제 Host의 ai_max_text_chars 기본값은 0으로 전송 문자 수를 제한하지 않으며, 실행 환경에 따라 필요한 상한을 설정할 수 있다. AI Server와 연동할 때는 서버의 입력 허용 범위에 맞춰 이 값을 설정한다. 모델 입력은 최대 128토큰으로 처리하므로 긴 문맥의 뒤쪽은 잘릴 수 있다. 전송 구간과 AI 서버는 신뢰 경계 안에 두어야 하며 시연에는 실제 개인정보가 아닌 명시적인 가상 데이터를 사용해야 한다. 예시의 점수와 추론 지연은 계약 설명용 값이지 측정 결과가 아니다.

분석 API는 Pydantic으로 필수 필드와 응답 decision enum을 정의하고 빈 snippet을 400으로 거절한다. 현재 Colab 시연 구성은 신뢰된 환경을 전제로 하며, Bearer 인증, 요청 byte 상한, 채널 enum·문자열 길이·점수 범위의 강화 검증은 운영 배포 단계의 적용 항목이다. 분석 JSONL에는 user_id, 매칭 패턴과 snippet 앞 200자를 저장한다. 최근 로그를 반환하는 debug API는 인증을 적용하지 않으므로 사용 범위를 신뢰된 시연 환경으로 한정한다.

server.py는 !pip, !wget, !chmod를 포함한 Google Colab 셸 실행 형식으로 구성하였다. 서버는 고정 Google Drive 경로에서 tokenizer와 모델을 불러와 로드 상태를 확인한다. 운영 배포 범위에는 checkpoint hash·label mapping·번들 무결성 확인을 포함한다. 임시 Cloudflare Tunnel 주소는 세션마다 바뀌므로 시연 시 새 URL을 Host 설정에 반영한다.

3.4. Web Dashboard 설계 및 구현

3.4.1. 서버와 로그 저장

Web은 FastAPI 애플리케이션, SQLite 데이터베이스와 단일 HTML/JavaScript 화면으로 구성된다. Host는 POST /api/v1/logs에 X-Agent-Token을 포함하여 사건을 전송한다. 입력 모델은 필수 필드, enum, 문자열·배열 길이와 점수 범위를 검사하고, SUCCESS 사건에만 0.0–1.0 범위의 ai_score를 허용한다. 사건 시각은 시간대 정보를 포함해야 하며 저장 전에 UTC로 정규화한다.

FastAPI는 Pydantic 기반 입력 검증과 OpenAPI 명세를 하나의 모델에서 관리할 수 있어 Host–Web JSON 계약을 명확히 하기 위해 선택했다. SQLite는 별도 DB 서버가 필요 없는 단일 시연 서버에 맞춘

선택이다. 동기 DB 처리 엔드포인트는 일반 def로 정의해 FastAPI의 worker thread에서 실행한다. 다중 worker와 대규모 동시 쓰기는 운영 확장 단계에서 별도의 부하 시험과 함께 적용한다.

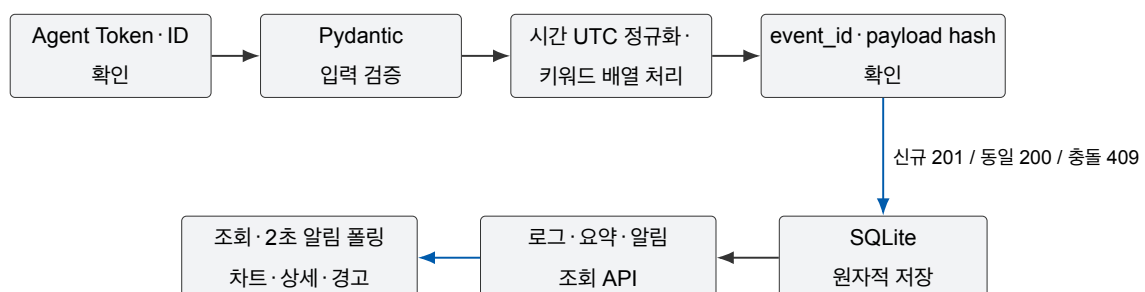
서버는 event_id의 unique index와 payload hash를 이용하여 Agent의 재전송을 멍등하게 처리한다. 새로운 사건은 201로 저장하고, 같은 ID와 같은 내용은 기존 사건을 반환한다. 같은 ID에 다른 내용이 도착하면 409로 거부하여 하나의 식별자에 서로 다른 사건이 연결되는 것을 방지한다. 로그에는 Agent·장치·사용자, 파일과 채널, 탐지 방식, AI 분석 상태와 점수, 모델 버전, 매칭 패턴, 조치 코드, 판정 사유와 AI 서버 내부 추론 지연을 저장한다. Web 스키마는 model_version을 지원하며, Host payload 연계는 계약 정합화 범위에 포함한다.

핵심 테이블의 역할은 표 3.5과 같다. 현재 구조는 agent_id, policy_id, event_id의 연결을 API 검증과 조회에서 관리하는 논리적 관계로 구성하였다. 이를 통해 Agent·정책 등록 순서와 무관하게 사건을 먼저 수집할 수 있다. 운영 확장 단계에서는 Agent·정책 원장과 migration 절차를 고정하고 SQLite foreign key로 참조 무결성을 강화한다.

테이블	기준 식별자	역할
dlp_logs dlp_metadata	log_id, event_id metadata_key	사건·채널·AI 상태·조치·근거의 중앙 저장 DB 세대(epoch)를 저장하여 알림 cursor 재동기화에 사용
dlp_agent_heartbeats dlp_policies	agent_id, mode policy_id	Agent 실행 모드별 최종 heartbeat 상태 예시 정책 정의의 생성·조회; Host 집행 연계는 확장 범위
dlp_policy_audit	audit_id	API를 통한 정책 생성 이력의 추가 전용 기록
dlp_ingest_conflicts	conflict_id	동일 event_id에 다른 payload가 도착한 409 충돌 기록

[표 3.5] Web SQLite 핵심 테이블과 역할

그림 3.6은 JSON 수신·파싱 이후의 처리 순서다.



[그림 3.6] Web 로그 수집에서 화면 갱신까지의 처리 파이프라인

3.4.2. 대시보드와 검색

대시보드는 UTC 기준 최근 7개 날짜의 관제 사건 수, 기록 사건 중 BLOCKED 비율, 평균 AI 점수, AI 분석 실패율과 부서·채널별 분포를 제공한다. API는 기간, 부서, 사용자, Agent, 조치, 채널과 통합 검색 조건을 지원하며 로그 목록은 서버에서 페이지 단위로 조회한다. 그림 3.7에는 KPI와 통계 영역을, 그림 3.8에는 로그 목록과 상세 확인 패널을 나타냈다. 두 화면은 기능 확인용 합성 로그를 표시한 결과이며 실제 Host-AI-Web E2E 측정값이 아니다.

AI 분석 상태는 SUCCESS, FAILED, SKIPPED로 구분한다. 정상 분석에 성공한 사건만 0.0–1.0 범위의 ai_score를 가지며, 실패 또는 미실행 사건의 점수는 NULL로 저장한다. 평균 AI 점수는 SUCCESS 사건만 대상으로 계산하고, AI 실패율은 FAILED/(SUCCESS+FAILED)로 별도 집계한다.

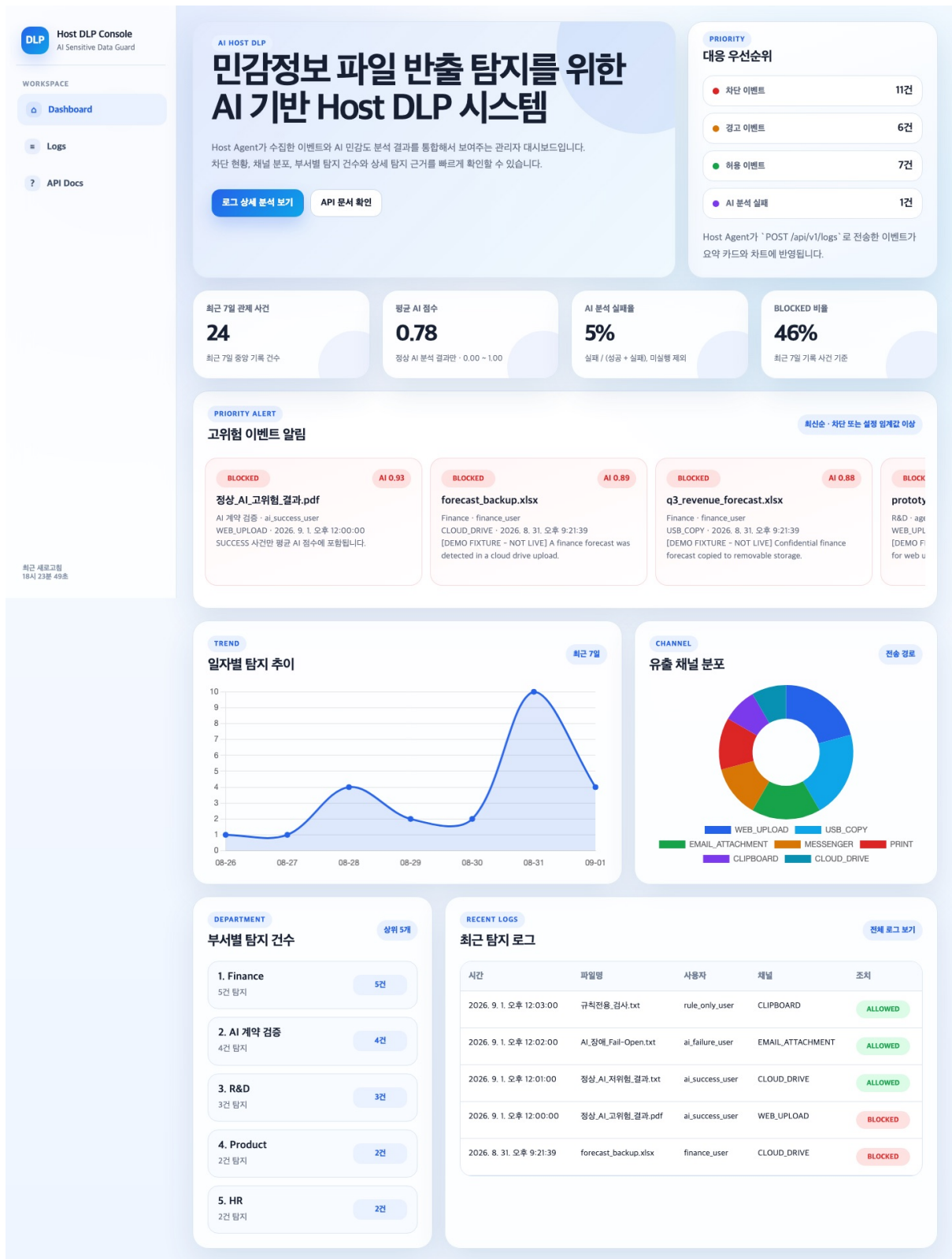
상세 화면에서는 목록의 요약 정보뿐 아니라 AI 분석 상태와 점수, 판정 사유, 탐지 근거, 매칭 패턴과 처리 결정, AI 서버가 보고한 추론 지연을 함께 확인할 수 있다. 이는 관리자가 “왜 차단되었는가”를 확인하고 규칙이나 임계값을 조정하는 데 필요한 기본 정보를 제공한다.

3.4.3. 준실시간 위험 알림

대시보드의 고위험 목록은 UTC 기준 최근 7개 날짜의 위험 사건을 최대 20건 표시한다. 이와 별도로 브라우저는 약 2초 간격으로 알림 API를 조회한다. 첫 요청은 과거 사건을 재생하지 않고 최신 log_id와 DB epoch만 기준선으로 받는다. 같은 DB epoch가 유지되는 동안에는 화면을 연 이후 생긴 사건만 토스트와 경고음 대상으로 삼지만, DB 교체로 epoch가 달라지면 새 세대의 기존 고위험 행을 log_id=0부터 페이지 단위로 재동기화한다. 최종 조치가 BLOCKED인 사건은 점수와 관계없이 대상이고, 그 밖에는 서버의 고위험 점수 임계값 이상인 사건을 표시한다. 고위험 점수의 기본값은 0.85이며 AI Server의 block 임계값 0.41과는 별도이다. 알림 대상은 화면 토스트와 경고음으로 관리자에게 전달한다.

일반 로그는 임의 필터와 페이지 이동을 위해 offset 방식을, 신규 알림은 순차적 발생을 놓치지 않도록 log_id cursor를 사용한다. 2초 폴링은 단일 시연 서버에서 연결 복구와 오류 처리를 단순화하려는 선택이다. 다수 관리자가 접속하는 운영 환경에서는 Server-Sent Events나 WebSocket으로 전송 구조와 성능 시험을 확장한다.

판정과 알림에 쓰이는 임계값은 표 3.6처럼 용도별로 구분하였다.



[그림 3.7] 기능 확인용 합성 데이터의 KPI 및 통계 화면(실제 탐지 성능 결과가 아님)

DLP
Host DLP Console
AI Sensitive Data Guard

WORKSPACE

Dashboard

Logs

API Docs

LOG ANALYSIS

탐지 로그 상세 분석

조건 기반으로 로그를 좁혀 보고, 선택한 로그의 Host 정보, Agent 식별자, AI 점수, 매칭 키워드와 탐지 근거를 확인합니다.

EVIDENCE

탐지 로그 조회

10만큼 보기

파일명, 경로, 사용자, Agent, 이벤트 ID 검색

전체 조치

전체 AI 상태

전체 채널

전체 부서

전체 사용자

mm/dd/yyyy

mm/dd/yyyy

새로고침

필터 결과 13건 중 1-10건 표시

필터 변경 시 로그 목록과 상세 선택이 갱신됩니다.

시간	사용자 / PC	파일명	채널	연진 / AI 상태	AI 점수	조치	근거
2026. 9. 3. 오전 1:02:50	security_user demo-host-01 (192.168.10.50)	AI 분석 실패 차단.txt C:\Security\AI_분석 실패 차단.txt	WEB_UPLOAD	HYBRID FAILED	-	BLOCKED	secret, analysis_failed [DEMO FIXTURE - NOT LIVE] AI 분석 실패로 Fail-Closed 차단 처리됨.
2026. 9. 2. 오후 8:21:00	sales_user demo-host-03 (192.168.10.43)	enterprise_contract_terms.docx C:\Sales\enterprise_contract_terms.docx	EMAIL_ATTACHMENT	RULE_BASED SKIPPED	-	WARNED	contract, discount, nda [DEMO FIXTURE - NOT LIVE] Contract terms require user confirmation before external email.
2026. 9. 2. 오후 7:14:00	finance_user demo-host-02 (192.168.10.42)	quarterly_revenue_forecast.xlsx C:\Finance\quarterly_revenue_forecast.xlsx	USB_COPY	HYBRID SUCCESS	0.92	BLOCKED	revenue, forecast, confidential [DEMO FIXTURE - NOT LIVE] Confidential finance data was copied to removable storage.
2026. 9. 2. 오후 6:07:00	research_user demo-host-01 (192.168.10.41)	prototype_source_export.zip C:\Research\prototype_source_export.zip	WEB_UPLOAD	HYBRID SUCCESS	0.96	BLOCKED	source_code, api_key, prototype [DEMO FIXTURE - NOT LIVE] AI score exceeded the web upload block threshold.
2026. 9. 1. 오후 10:35:00	product_user demo-host-05 (192.168.10.45)	launch_roadmap_internal.pdf C:\Product\launch_roadmap_internal.pdf	MESSENGER	HYBRID SUCCESS	0.42	ALLOWED	roadmap, internal [DEMO FIXTURE - NOT LIVE] Internal collaboration remained below the warning threshold.

이전
1 / 2 페이지
다음

AI 분석 실패 차단.txt

로그 ID 13 · 2026. 9. 3. 오전 1:02:50

BLOCKED

사용자 / 부서

security_user · Security

Agent / Event

senry-demo-agent-01
demo-report-ai-failed-blocked

프로세스 / 정책

chrome.exe · DLP-WEB-001

탐지 방식 / AI 상태 / AI 점수

HYBRID · FAILED · -

응답 지연

-

Host 정보

demo-host-01 (192.168.10.50)

파일 경로

C:\Security\AI_분석 실패 차단.txt

канал

WEB_UPLOAD

AI 모델 버전

-

탐지 근거

[DEMO FIXTURE - NOT LIVE] UI 상태 표시 확인을 함성 사진.
[DEMO FIXTURE - NOT LIVE] AI 분석 실패로 Fail-Closed 차단 처리됨.

secret
analysis_failed

최근 새로고침

1시 2분 51초

[그림 3.8] 기능 확인용 합성 데이터의 이벤트 로그 화면(실제 탐지 성능 결과가 아님)

기준	값	효력
AI allow/review 경계	0.20	AI Server의 3단계 판정에 사용(Host는 반환 decision 집행)
AI review/block 경계	0.41	AI Server의 3단계 판정에 사용(Host는 반환 decision 집행)
Web 고위험 알림	기본 0.85 또는 BLOCKED	관제 화면의 강조·알림에만 사용

[표 3.6] 서로 다른 임계값의 용도와 실제 효력

3.4.4. 접근 제어

Host의 쓰기 요청은 Agent Token으로 인증한다. Agent별 Token을 사용하는 경우 X-Agent-ID와 payload의 agent_id가 일치해야 한다. 대시보드는 Viewer와 Admin 역할의 HTTP Basic 인증을 선택적으로 적용할 수 있다. 기본 개발 구성은 단일 시연 환경을 전제로 하며, 공유망 배포 구성에서는 개발용 비밀번호를 교체하고 인증과 HTTPS를 활성화한다. /docs, /redoc, /openapi.json에는 대시보드 인증 dependency가 적용되지 않으므로 공유망에서는 비활성화하거나 리버스 프록시로 보호한다.

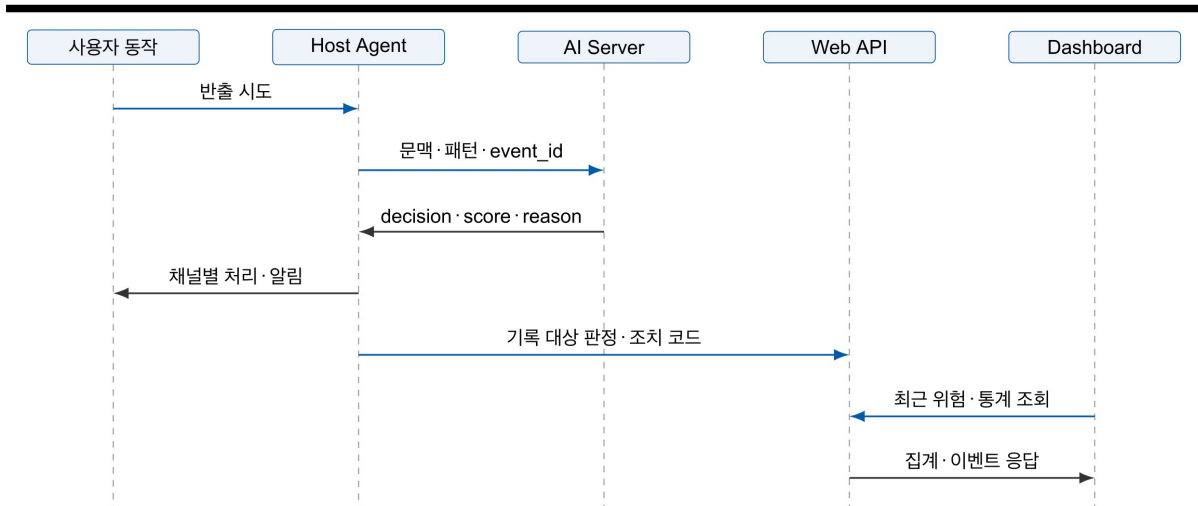
Web의 정책 API는 정의 생성·조회와 생성 감사 기능을 제공한다. 현재 연동 범위에서 Web은 중앙 관제 서버를 담당하며, Host의 정책 조회·집행 연계는 운영 확장 항목으로 둔다.

Web 파트의 기술적 기여는 일반적인 CRUD 화면보다 관제 상태의 신뢰성을 다룬 데 있다. 재전송을 멍등하게 처리하고 다른 payload 충돌을 분리했으며, AI 실패와 미실행을 점수 NULL이 가진 별도 상태로 보존했다. 또한 cursor와 DB epoch로 알림의 중복·누락·DB 교체 경계를 다루고, 이 상태 변환을 자동화 시험으로 확인한 것이 핵심이다.

3.5. 구성 요소 간 API와 데이터 흐름

3.5.1. 이벤트 순서

정규식 적중 후 기록 대상으로 전달되는 사건 한 건의 순서를 그림 3.9에 나타냈다.



[그림 3.9] 기록 대상 반출 이벤트의 구성 요소 간 처리 순서

화면과 Host가 실제로 사용하는 핵심 Web API를 표 3.7에 정리하였다. 조회 API의 성공 응답은 200이며, 입력 모델·query 검증 실패는 422, 인증 실패는 401, 인증된 Agent ID 불일치나 역할 권한 부족은 403으로 구분한다.

엔드포인트	호출 주체·인증	주요 입력·응답
POST /api/v1/logs	Host·Agent Token	사건 payload; 신규 201, 동일 재전송 200, 다른 payload 충돌 409
GET /api/v1/logs	Dashboard·Viewer/Admin	기간·사용자·Agent·채널·조치·검색·페이지; items, total
GET /api/v1/logs/{log_id}	Dashboard·Viewer/Admin	사건 식별자; 전체 상세 필드, 미존재 404
GET /api/v1/dashboard/summary	Dashboard·Viewer/Admin	days; KPI, 날짜·채널·부서 집계
GET /api/v1/alerts	Dashboard·Viewer/Admin	after_log_id, cursor_epoch; 신규 고위험 사건과 다음 cursor

[표 3.7] Host·Dashboard가 사용하는 핵심 Web API

3.5.2. Host에서 Web으로 보내는 로그

Host가 Web으로 전송하는 사건·단말·파일·탐지·조치 필드를 표 3.8에 정리하였다. Host는 알 수 없는 필수값에 의미가 명확한 대체값을 채우고, 선택 필드만 생략한다.

구분	대표 필드	설명
사건 식별	event_id, timestamp	중복 방지와 구성 요소 간 추적에 사용
단말·사용자	agent_id, host_ip, hostname, user_id, department	사건이 발생한 환경을 구분
파일·채널	file_name, file_path, process_name, leak_channel	반출 대상과 경로를 기록
탐지 결과	detection_type, analysis_status, ai_score, model_version, matched_keywords	AI 분석 상태·점수·버전과 규칙 탐지 근거를 기록
조치	action_taken, decision_reason, evidence_summary	Host가 기록한 판정·조치 코드를 저장
성능	latency_ms	AI Server 응답에 포함된 서버 내부 추론 지연을 기록

[표 3.8] 중앙 로그의 주요 필드

현재 Host의 명시적 채널 매핑은 표 3.9과 같다.

Host/AI 채널	Web leak_channel	비고
clipboard	MESSENGER	클립보드 전용 Web enum을 사용하지 않음
web_mail, http	WEB_UPLOAD	웹메일·일반 웹 업로드
drive_upload	MESSENGER	현재 기본값으로 저장되며 전용 채널 매핑 정합화 대상
file_guard, usb	USB_COPY	이동식 매체 복사
print, messenger	동일 이름의 Web enum	Web enum 지원; Host 전용 혹은 확장 범위

[표 3.9] Host·AI 채널에서 Web 관제 채널로의 매핑

현재 Host의 정상 전송 경로에서는 정규식 후보 중 AI block 또는 review 사건만 중앙에 전달한다. Web 스키마는 ALLOWED도 저장할 수 있으며 화면의 ALLOWED 항목은 기능 확인용 합성 데이터다. 정상 미적중과 AI allow, Web Proxy 처리 예외는 Host의 중앙 사건으로 만들지 않는다. 따라서 중앙 로그의 집계 범위는 block·review 사건이며, 모든 사용자 동작과 AI 판정의 모수와 구분한다. action_taken은 채널이 기록한 조치 코드이다. Clipboard 재발행, Web Proxy 451 생성과 USB 삭제의 실제 수행 결과를 중앙 상태에 연계하는 기능은 계약 정합화 범위에 포함한다.

3.6. 보안 및 장애 대응

세 구성 요소는 서로 다른 신뢰 경계를 가진다. Host-Web 쓰기 요청은 X-Agent-Token, 관리자 화면은 Viewer/Admin HTTP Basic을 사용한다. Agent별 Web 토큰 모드에서는 X-Agent-ID도 필수이며 인증된 Agent ID와 payload의 agent_id가 일치해야 한다. Host-AI 분석 요청은 신뢰된 시연 환경을 전제로 하며, 공유망 배포 구성에는 AI API 인증과 새 비밀정보를 적용한다.

원문은 구간별로 다르게 취급된다. 문맥 추론을 위해 Host가 정규식 일치 주변 원문을 AI로 보내므로 전송 중 보호와 서버 접근통제가 필수이다. Host JSONL은 기본 120자 미리보기와 SHA-256을 함께 저장하고, AI 감사 로그는 사용자 ID와 snippet 앞 200자를 남긴다. Web DB에는 사용자, 파일명·경로, 판정 사유와 근거가 평문으로 저장된다. 시연에는 실제 개인정보가 아닌 합성 데이터를 사용하며, 운영 배포 구성에는 파일 암호화, 최소 권한, 마스킹, 보존 기간, 안전한 삭제와 세 로그의 원문 범위 최소화를 적용한다.

Web Proxy 방식은 HTTPS 내용을 검사하기 위해 현재 사용자 CA와 시스템 프록시를 변경한다. HTTP/3의 QUIC가 프록시를 우회하지 않도록 UDP/443 차단 규칙과 실제 프록시 listener를 사전 점검한다. 실제

chunk 업로드 경로는 브라우저 기반 시나리오에서 추가 확인한다. 시연 전후에는 CA·프록시·방화벽 설치와 복구 절차를 수행하고, 운영 장비에는 조직의 승인된 인증서 수명주기와 브라우저 정책을 적용한다.

장애 처리에서 Host는 AI 실패를 Fail-Closed로 차단하고 실패 사건을 BLOCKED, FAILED, 점수 NULL로 기록한다. 실제 AI URL을 사용했다면 탐지 방식은 HYBRID로 기록한다. 중앙 Web 전송 실패는 분석·조치와 분리되어 로컬 JSONL에 남고 재시도할 수 있으며, Web은 같은 event_id의 중복 삽입을 방지한다.

Web은 프로토타입 범위에서 단일 SQLite 파일과 서버 측 페이지 조회를 사용한다. 공유망 또는 대용량 환경에서는 HTTPS 강제, Dashboard 인증, DB 접근통제·백업·보존 정책, 시간대가 일치하는 날짜 필터와 부하 시험으로 운영 범위를 확장한다.

4. 구현 결과 및 검증

4.1. 검증 체계

검증은 네 수준으로 구분하였다. 첫째, 구현 상태와 데이터 계약을 확인한다. 둘째, 반복 가능한 자동화 시험으로 입력 경계와 상태 변환을 확인한다. 셋째, loopback Uvicorn과 Chromium E2E 시험으로 API와 화면 상호작용을 확인한다. 넷째, Windows 혹은 실제 사용자 조치, 다른 PC의 HTTPS LAN 수신을 포함한 통합 E2E를 수행한다. 상위 수준의 테스트가 하위 수준을 포함한다고 가정하지 않으며, 각 결론은 해당 증거 범위 안에서만 제시한다.

표 4.1는 가독성을 위해 서버 파이프라인과 실장비 E2E 상태를 마지막 열에 함께 제시한다.

구성 요소	구현·계약 확인	자동화 테스트	서버 파이프라인·실장비 E2E
Web	API, DB, 인증, 먹등성, AI 상태, 화면 계약 확인	API·DB·스크립트와 Chromium E2E 시험 통과	loopback 화면 상호작용 확인; 타 PC HTTPS LAN은 현장 검증 범위
Host Agent	채널·추출·조치 코드와 Web payload 확인	Web 전송 계약 시험 4건 통과	채널별 평균 지연 벤치마크 반영; 자원 사용량·P95·채널 E2E는 확장 측정 범위
AI Server	데이터·학습 스크립트와 Colab용 3단계 API 확인	실시간 API 배치 검증 수행	독립 홀드아웃 60건 확인; 실제 기업 문서 기반 대규모 표본으로 확장
전체 통합	event_id와 주요 필드의 연결 관계 정리	구성 요소별 인터페이스 계약 확인	Host-AI-Web 라이브 통합 E2E로 확장

[표 4.1] 구성 요소별 검증 결과와 결론의 범위

4.2. 기능 자동화 검증

Web의 API·DB·스크립트 시험 128건과 Chromium 기반 Playwright E2E 3건, 총 131건이 통과하였다. 로그 저장과 먹등성, 인증, 입력값 검증, AI 분석 상태, 조회·집계와 위험 알림 API를 확인하였다. Chromium 시험은 필터와 페이지 이동, 상세 조회, 오류 표시, 비동기 응답 경험, 위험 알림 토스트와 경고음 동작을 확인하였다. 대표 시험의 입력 경계와 확인 결과는 표 4.2와 같다.

검증 대상	입력 · 조건	확인 결과
Agent 인증	Token 누락 · 오류, Agent ID 누락 · 불일치	각각 401 · 422 · 403 거부
먹등 저장	신규, 동일 재전송, 동일 ID · 다른 payload	201 · 200 · 409 분기와 충돌 감사 기록
AI 상태 계약	SUCCESS/FAILED/SKIPPED와 점수 조합	성공은 점수 필수, 실패 · 미실행은 NULL 강제
조회 · 집계 준실시간 알림	필터, 페이지, 상세, 기간별 집계 초기 cursor, DB epoch 변경, 연속 고위험 로그	건수 · 순서 · KPI 응답 일치 과거 재생 방지 · 재동기화 · 페이지 이어받기 확인
화면 경합 · 접근성	느린 이전 응답, 키보드 상세 조회, 신규 위험 사건	최신 응답 유지 · 상세 열기 · 토스트 · 경고음 확인

[표 4.2] Web 자동화 시험의 대표 근거

Host는 Web payload 전송 계약 4건으로 점수 척도, Agent ID 헤더, analysis_failed 표현과 명시적 timeout을 확인하였다. 클립보드 · 웹메일 · 클라우드 드라이브 · USB의 실제 조치는 실장비 시나리오 검증 범위로 구분하였다. AI Server는 batch_test_live_api.py로 실시간 API 배치 검증 233건을 수행하여 Recall, 오답률과 응답 지연을 산출하였다. server.py는 Google Colab 셸 환경을 기준으로 실행 · 검증하였다. 구성 요소별 자동화는 인터페이스 계약을 확인하고, 전체 연동은 별도의 실장비 E2E 절차로 평가한다.

4.3. 성능 벤치마크 결과

4.3.1. 테스트 환경

Host Agent

항목	내용
OS	Windows 11 Home 25H2 (빌드 26200.9168)
CPU	Intel Core i5-13400F
RAM	32 GB

AI Server

항목	내용
OS	Windows 11 Pro 25H2 (빌드 26200.9168)
CPU	Intel(R) Core(TM) i5-14400F @ 2.50GHz
RAM	32 GB
GPU	NVIDIA GeForce RTX 4060 (미사용, torch CPU 빌드로 실행)

4.3.2. 테스트 측정 방법

본 절의 시험 구성과 수치는 성능 측정 당시의 설정과 결과 자료를 기준으로 한다.

본 성능 측정은 Sentry Host Agent의 4개 반출 탐지 채널(클립보드, 웹 메일, 클라우드 드라이브, USB 이동식 드라이브)을 대상으로, 34개 파일 형식 × 5개 크기 구간(10 KB, 100 KB, 1 MB, 10 MB, 50 MB) = 채널당 170개 케이스, 총 680개 테스트 케이스에 대해 수행하였다. 각 테스트 케이스는 민감정보 패턴(주민등록번호, 휴대폰·일반 전화, 이메일, 계좌번호)이 삽입된 더미 파일을 사용하였으며, 각 구간의 소요 시간을 밀리초(ms) 단위로 측정·기록하였다.

4.3.3. 파이프라인 구간 정의

DLP 파이프라인은 다음 6개 구간으로 구성된다. 모든 구간 시간의 합이 전체 탐지·차단 응답 시간(total latency)을 구성한다.

구간	기호	설명
텍스트 추출	① extract	파일 형식에 따라 텍스트를 파싱·추출하는 시간. USB 채널은 파일 쓰기 완료 대기(1,000 ms)가 포함됨
정규식 검사	① regex	추출 텍스트에 대한 DLP 정규식 패턴 매칭 시간
AI 전송	② send	에이전트 → AI 서버 네트워크 전송 시간 (왕복의 절반)
AI 처리	③ ai	AI 서버의 KoELECTRA 모델 추론 처리 시간
AI 수신	④ recv	AI 서버 → 에이전트 네트워크 수신 시간 (왕복의 절반)
차단 실행	⑤ block	채널별 차단 조치 실행 시간 (팝업·HTTP 451·파일 삭제)

4.3.4. 채널별 성능 측정 결과

(1) 클립보드 채널

클립보드 채널은 사용자의 붙여넣기(Ctrl+V) 시점에 클립보드 텍스트 및 파일 내용을 가로채어 검사한다. 차단 조치는 팝업 알림 창 표시로 이루어진다.

파일 크기별 평균 파이프라인 지연 시간 (단위: ms)

파일 크기	㉠ extract	① regex	② send	③ ai	④ recv	⑤ block	total
10 KB	6.93	1.14	221.71	276.73	221.71	38.30	766.52
100 KB	7.54	7.27	226.90	273.20	226.90	40.20	782.01
1 MB	64.38	73.05	228.20	275.84	228.20	39.60	909.27
10 MB	636.18	727.15	236.11	272.50	236.11	41.10	2,149.15
50 MB	1,065.94	3,566.66	230.34	263.36	230.34	38.70	5,395.34

(2) 웹 메일 채널

웹 메일 채널은 HTTPS MITM 프록시(mitmproxy)를 통해 Gmail 등 웹메일 서비스의 첨부파일 업로드 요청을 가로채어 검사한다. 차단 조치는 HTTP 451 응답으로 업로드를 즉시 차단한다.

파일 크기별 평균 파이프라인 지연 시간 (단위: ms)

파일 크기	㉠ extract	① regex	② send	③ ai	④ recv	⑤ block	total
10 KB	7.24	1.17	225.32	248.17	225.32	1.28	708.50
100 KB	9.39	7.29	226.89	245.98	226.89	1.41	717.85
1 MB	90.71	72.81	229.29	244.91	229.29	1.35	868.36
10 MB	923.45	717.59	235.46	246.43	235.46	1.27	2,359.66
50 MB	2,528.37	3,584.40	274.05	285.01	274.05	1.46	6,947.34

(3) 클라우드 드라이브 채널

클라우드 드라이브 채널은 웹 메일 채널과 동일한 HTTPS MITM 프록시 위에서 동작하며, Google Drive 등 클라우드 스토리지 업로드 요청을 대상으로 한다. 차단 조치는 웹 메일과 동일하게 HTTP 451 응답을 사용한다.

파일 크기별 평균 파이프라인 지연 시간 (단위: ms)

파일 크기	㉠ extract	① regex	② send	③ ai	④ recv	⑤ block	total
10 KB	7.37	1.30	224.21	291.52	224.21	1.54	750.15
100 KB	11.06	8.25	243.47	292.98	243.47	1.67	800.90
1 MB	96.38	78.18	248.52	270.76	248.52	1.58	943.94
10 MB	1,128.56	832.39	312.28	283.59	312.28	1.71	2,870.81
50 MB	2,618.44	3,699.48	276.85	266.21	276.85	1.48	7,139.31

(4) USB 이동식 드라이브 채널

USB 채널은 ReadDirectoryChangesW API를 통한 파일 시스템 변경 감지 방식으로, 파일이 USB에 쓰인 직후 검사를 수행한다. 민감정보 탐지 시 파일을 즉시 삭제하고 팝업 알림을 표시하는 detect-and-remediate 방식으로 동작한다.

파일 크기별 평균 파이프라인 지연 시간 (단위: ms)

파일 크기	㉔ extract	㉑ regex	㉒ send	㉓ ai	㉔ recv	㉕ block	total
10 KB	2,009.11	1.36	304.85	241.64	304.85	69.40	2,931.21
100 KB	2,008.90	8.45	296.00	242.67	296.00	71.30	2,923.32
1 MB	2,072.24	83.43	296.69	276.37	296.69	70.80	3,096.22
10 MB	2,514.28	695.48	251.04	278.43	251.04	68.90	4,059.17
50 MB	3,295.77	3,918.40	296.23	278.81	296.23	72.10	8,157.54

4.3.5. 종합 분석

AI 서버 응답 시간

모든 채널에서 AI 추론 시간(㉓ ai)은 240~295 ms 범위로 일정하였으며, 이는 KoELECTRA 기반 분류 모델의 안정적인 추론 성능을 나타낸다. 네트워크 왕복 시간(send + recv)은 Cloudflare Tunnel 경유로 인해 약 440~650 ms 수준이었다.

파일 형식별 추출 시간 특성

텍스트·코드 계열 파일(.txt, .py, .js 등)은 10 MB에서도 extract가 20 ms 이내이나, Office 계열 파일은 형식 파싱 오버헤드로 인해 대용량에서 수십 초가 소요될 수 있다.

파일 분류	대표 형식	50 MB extract (최대)
텍스트·코드	.txt, .py, .js, .csv	~ 100 ms
문서 (Word, HWPX)	.docx, .hwp	1,000~1,200 ms
스프레드시트	.xlsx	4,000~7,000 ms
프레젠테이션	.pptx	800~900 ms
PDF	.pdf	4,600~5,500 ms
RTF	.rtf	20,000~22,000 ms

4.3.6. 결론

실사용 관점 응답성 평가

성능 측정 결과를 바탕으로, 실제 업무 환경에서의 사용성을 평가한다.

일반적인 업무 파일의 크기는 대부분 수십 KB에서 수 MB 범위에 해당한다. 이 구간(10 KB~1 MB)에서 클립보드·웹 메일·클라우드 드라이브 채널의 전체 응답 시간은 700~950 ms 수준으로, 사용자가 체감하기 어려운 범위이다. 민감정보 미탐지 시에는 DLP 파이프라인이 즉시 통과 처리되어 응답 지연이 전혀 발생하지 않는다.

채널별 실사용 영향 분석

클립보드 채널은 정규식 히트 시 붙여넣기를 즉시 차단한 뒤 AI 판단을 백그라운드 스레드에서 수행하므로, AI 응답 시간이 사용자 체감 지연에 직접 영향을 주지 않는다. 팝업 알림(약 39 ms)은 인지 가능한 수준이나 업무에 지장을 줄 만한 수준이 아니다.

웹 메일·클라우드 드라이브 채널은 파일 업로드 요청을 HTTPS 프록시에서 가로채어 검사하는 방식으로, 민감정보 미탐지 파일은 일반 업로드와 동일하게 통과된다. 탐지 시에는 HTTP 451 응답이 1~2 ms 이내에 반환되어 차단 자체의 처리 지연은 무시할 수 있는 수준이다.

USB 채널은 파일 복사 완료 후 검사를 수행하는 유저모드 방식의 특성상 구조적 대기 시간(1,000 ms)이 포함되어 전체 응답 시간이 약 3초로 상대적으로 길다. 그러나 이는 파일이 USB에 복사된 직후 에이전트가 개입하는 시점으로, 사용자 입장에서는 복사 직후 파일이 자동 삭제되는 형태로 동작하므로 실제 업무 흐름을 방해하지 않는다.

대용량 파일 처리

10 MB 이상의 대용량 파일에서는 텍스트 추출(extract)과 정규식 검사(regex) 구간이 전체 지연의 대부분을 차지한다. 특히 Excel, RTF, PDF 형식의 50 MB 파일은 처리 시간이 수초~수십 초에 달한다. 그러나 이러한 대용량 파일은 첨부·업로드 자체에 상당한 전송 시간이 소요되므로, DLP 처리 지연이 전체 사용자 경험에 미치는 영향은 제한적이다. 또한 실운영 환경에서는 ai_max_text_chars 설정을 통해 AI 전송 페이로드 크기를 제한함으로써 대용량 파일의 처리 시간을 추가로 단축할 수 있다.

종합

측정 결과, 일반 업무 환경에서 사용되는 파일(10 KB~1 MB)에 대해 모든 채널에서 1초 이내(USB 제외)의 탐지·차단이 이루어졌으며, 차단되지 않는 정상 파일에 대해서는 추가 지연이 발생하지 않는다. AI 추론 시간은 모든 채널에서 240~295 ms의 안정적인 범위를 유지하였고, 채널별 차단 조치(HTTP 451·팝업·파일 삭제)의 실행 지연도 대체로 70 ms 수준으로 나타나 실사용에 영향을 주지 않는 수준임을 확인하였다. 이를 통해 Sentry Host Agent는 사용자 업무 흐름을 저해하지 않으면서 실시간 민감정보 반출 탐지·차단이 가능한 수준의 성능을 갖추고 있음을 확인하였다.

4.4. AI 모델 성능 및 강건성 평가

업무 문체 평가에서 확인한 도메인 특성을 반영해 데이터를 도메인×기밀성 구성으로 재설계하였다. 이를 기반으로 v7 학습·추론 코드, 하드 테스트 스크립트와 0.20/0.41 임계값을 구성하였다.

4.4.1. Threshold 재검증

v7 모델 기준으로 정식 Test셋과 하드 테스트를 병합한 129건에 대해 ROC 분석을 수행한 결과 AUC 0.9949를 확인하였다. Youden's J statistic, F1-optimal, F2-optimal(Recall 가중) 세 기준이 공통으로 threshold ≈ 0.41 부근에 수렴하여 현재 서버에 적용된 0.41을 채택하였다. review 하한(0.20)은 동일 데이터에서 review/allow 경계를 스위치한 결과, 0.20 부근에서 비기밀 allow율의 추가 손실 없이 기밀 recall이 개선되는 지점으로 확인하였다.

4.4.2. 독립 홀드아웃 평가

v7의 정식 평가 20%와 하드 테스트는 임계값 조정에 활용하였다. 독립 일반화 성능을 확인하기 위해 학습과 임계값 선정에 사용하지 않은 신규 홀드아웃 60건(HR·영업·R&D 3개 도메인, 격식체·구어체 균형, 기밀 30·비기밀 30)을 별도로 구성하였다. threshold를 고정한 뒤 실제 배포 서버(Google Colab, Tesla T4 GPU)의 POST /api/v1/analyze를 통해 blind 평가하였다.

지표	값
기밀 Recall (30건)	30/30 (100%)
비기밀 오탐 (30건)	0/30 (0%)
격식체 Recall (16건)	16/16 (100%)
구어체 Recall (14건)	14/14 (100%)
평균 응답 지연	28.43 ms

[표 4.3] 독립 홀드아웃 60건 blind 평가 결과

본 결과의 적용 범위는 합성 데이터 60건이며, 향후 실제 기업 문서 기반 대규모 표본으로 독립 평가 범위를 확장한다. 응답 지연 수치(평균 28.43 ms)는 이 홀드아웃 60건에 한정된 측정으로, 4.4.4절에서 별도로 수행한 233건 측정과는 독립적인 실험이다.

4.4.3. 변형 표현 강건성 평가

본 실험은 Host Agent의 1차 정규식 필터를 거치지 않고 AI Server의 POST /api/v1/analyze를 직접 호출한 모델 단독 평가이다. 시스템 적용 결과는 Host의 정규식 후보 선별 범위와 함께 해석한다.

AI 모델의 변형 표현 식별 능력을 확인하기 위해 간격 삽입·숫자의 한글 표기 등으로 변형한 문장 37건(기밀 22, 비기밀 15)을 구성하였다. 이 중 6건은 원본과 변형본 쌍으로 confidence_score 변화를 직접 비교하였다.

변형 기법	기밀 Recall
간격 삽입 (10건)	9/10 (90.0%)
숫자의 한글 표기 (3건)	2/3 (66.7%)
트리거 없는 원문 (6건)	3/6 (50.0%)
암묵적 추론 (3건)	1/3 (33.3%)

[표 4.4] 변형 기법별 기밀 Recall

원본-변형 6쌍 비교에서는 변형 후 confidence_score가 하락한 사례가 없었으며(5건 상승, 1건 변화 없음), 비기밀 15건에서 노이즈로 인한 오탐은 발생하지 않았다(0/15). 트리거 단어 없이 사실관계만으로 민감도를 판단하는 암묵적 추론은 33.3%로 나타났으며, 해당 유형을 향후 데이터 확장의 우선 범주로 도출하였다.

4.4.4. 응답 지연시간

본 절의 수치는 AI Server 단독 응답시간(모델 추론 + API 처리)만을 측정한 것으로, 4.3절의 Host Agent 종단 지연(파일 추출·정규식·네트워크·조치 포함)과는 측정 범위가 다르다.

동일 Google Colab 환경(NVIDIA Tesla T4 GPU, Intel Xeon CPU 2vCPU @2.00GHz, RAM 12GB)에서 233건의 실시간 API 요청에 대한 응답 지연시간을 측정한 결과 평균 17 ms 내외, 95퍼센타일 18 ms 내외로 나타나 실시간 처리 요구사항을 충족함을 확인하였다.

AI 추론 모듈 자체는 CPU 환경에서 GPU 대비 약 10배 느렸으나(240 295 ms vs 17 30 ms), 전체 파이프라인 응답 시간에서는 이 차이가 사용자 체감에 영향을 줄 만큼 크지 않았다(일반 업무 파일 기준 700 950 ms, 4.3.6절 참고). 동일 모델을 GPU 환경 (Colab, Tesla T4)에 배포하여 실측한 결과, AI 추론 지연은 평균 17 30 ms 수준으로 나타나 실시간 처리 여유가 더 확보됨을 확인하였다.

4.5. Web 기능 검증 결과

API·DB·스크립트 시험에서 로그 저장과 먹등성, 필터·페이지 조회, 상세 조회, AI 상태별 점수 표현, 요약 집계와 커서 기반 위험 알림을 확인하였다. Chromium 기반 Playwright 시험에서는 필터와 페이지 이동, 키보드 상세 조회, API 오류와 비동기 응답 경합, 토스트와 경고음을 확인하였으며 관련 시험이 모두 통과하였다. 필터에는 SUCCESS, FAILED, SKIPPED AI 상태가 포함되고, 실패·미실행 사건의 점수는 “-”로 표시된다.

화면의 합성 로그는 UI 기능 검증에 사용하며 실제 탐지 성능 및 운영 통계와 구분한다. 중앙 수집·조회·관제 프로토타입의 API·DB 계약은 반복 가능한 시험으로 확인하였다. 다음 현장 검증은 물리적으로 분리된 다른 PC의 HTTPS LAN에서 실제 Host 로그를 수신하는 범위로 확장한다.

4.6. 시나리오별 구현 및 검증 결과

주요 반출 시나리오와 중앙 알림의 구현·자동화·실장비 확인 범위를 표 4.5에 정리하였다.

시나리오	구현 내용	중앙 기록 상태	실장비 검증 범위
클립보드 붙여넣기	정규식 적중 시 억제, block/review 유지, allow 1회 재발행	현재 MESSENGER 기본 매핑; 전용 채널 정합화 대상	실제 Ctrl+V, 텍스트·CF_HDROP, UIPI와 대상 변경
USB 파일 복사	REMOVABLE 대상의 복사 완료 후 os.remove 시도	file_guard → USB_COPY; 삭제 실패도 BLOCKED 유지	폐기 가능 USB에서 대상 파일 실제 소멸
웹메일 업로드	block·review 판정 시 HTTP 451을 반환하여 업로드 차단	web_mail → WEB_UPLOAD; 응답 생성 예외 상태 연계 대상	CA·프록시·QUIC와 실제 웹메일 계정
클라우드 업로드	Drive·MYBOX 등 지원 도메인을 Web Proxy에서 분류	현재 MESSENGER 기본 매핑; 전용 채널 정합화 대상	실제 서비스 업로드와 매핑 수정 확인
위험 알림	cursor·epoch·백오프와 Chromium 토스트·경고음 시험 통과	BLOCKED 또는 기본 0.85 이상	다른 PC의 HTTPS LAN 수신과 현장 경고음

[표 4.5] 발표 핵심 시나리오별 현재 상태

실장비 E2E는 같은 실행의 (1) Host 사전 점검, (2) AI health의 모델 로드 상태와 임계값, (3) 규칙 후보와 AI 응답, (4) 운영체제·응용프로그램 조치, (5) 로컬 JSONL, (6) Web 신규 저장 201·동일 재전송 200·충돌 409와 재조회를 같은 event_id로 연결하여 확인한다. USB는 대상 파일 소멸, Clipboard는 재발행, Web은 HTTP 451을 함께 확인한다.

4.7. 통합 검증 범위와 확장 항목

현재 검증 범위와 운영 확장 항목은 다음과 같다.

1. 다른 PC의 HTTPS LAN에서 실제 Host 로그를 수신하는 절차는 현장 검증 범위로 둔다.
2. Windows 클립보드·웹메일·클라우드 드라이브·USB의 통합 E2E는 실장비 환경에서 수행한다.
3. 독립 홀드아웃 60건 평가를 바탕으로 부서·문서 유형 단위 분할과 실제 기업 문서 기반 대규모 표본으로 일반화 검증을 확장한다.
4. 채널별 평균 종단 지연을 확보하였으며, CPU 평균·최댓값, 최대 메모리 사용량과 P95로 자원 성능 측정 범위를 확장한다.
5. AI 분석 후보는 현재 정규식이 적중한 문장으로 한정된다.
6. Host의 중앙 전송 범위는 block·review 사건이다. USB 삭제와 HTTP 451 생성의 실제 수행 결과를 중앙 상태에 연계하여 BLOCKED의 의미를 세분화한다.
7. Clipboard·Cloud Drive의 중앙 채널 매핑과 AI 응답의 model_version 전달은 구성 요소 간 계약 정합화 항목이다.
8. USB는 사후 삭제 방식이며, 실장비 E2E에서 대상 파일의 실제 소멸을 함께 확인한다.

-
9. 운영 보안 확장에는 Host·AI 로그의 원문 범위 최소화와 Host-AI 요청 인증을 포함한다.
 10. Web 운영 구성에는 Dashboard 인증·HTTPS와 SQLite 파일의 접근통제·백업·보존 정책을 적용한다.
 11. UTC/KST 날짜 경계와 대용량 로그 응답시간은 운영 규모 검증 항목으로 둔다.
 12. 물리 환경의 토큰·인증서 교체와 장애 복구 절차는 운영 검증 범위에 포함한다.

다음 단계에서는 채널·조치·모델 버전·AI 인증 계약 정합화, 실제 기업 문서 기반 대규모 독립 모델 평가, Windows 4채널 E2E와 실장비 성능 측정, 물리 환경의 운영 보안 절차 순으로 검증 범위를 확장한다.

5. 결론 및 향후 연구 방향

5.1. 연구 결과 요약

본 연구는 Windows 단말의 민감정보 반출 후보를 정규식과 KoELECTRA 기반 문맥 분석으로 판단하고, 결과를 중앙 Web 대시보드에 기록하는 Host DLP 프로토타입을 설계하였다. Host는 클립보드, 웹메일, 클라우드 드라이브와 USB 채널을 공통 분석 파이프라인에 연결하였고, AI 서버는 3단계 판정 API를 제공한다. Web은 FastAPI와 SQLite를 이용해 로그 저장, 검색, 통계, 상세 근거와 준실시간 경고를 구현하였다.

Host가 부여한 event_id를 AI 요청·로컬 기록·Web 저장에 재사용하고, Web이 이를 역등하게 저장·조회하는 중앙 연동 기반을 구현하였다. 운영 확장 단계에서는 Clipboard·Cloud Drive 채널 매핑, AI model_version 전달과 실제 조치 결과의 중앙 상태를 정합화한다. AI 장애에는 Host의 Fail-Closed block 정책을 적용한다.

연구 질문별로는 (1) 공통 이벤트와 채널별 모듈을 구성하고 중앙 채널 매핑의 정합화 범위를 정의하였으며, (2) 규칙 후보와 3단계 AI 판정을 결합하고 장애 시 Fail-Closed를 적용하였다. (3) 조치 코드를 중앙 기록과 연결하고 물리 조치 결과의 세분화를 운영 확장 범위로 두었으며, (4) 구현 확인·구성 요소별 자동 시험·실장비 E2E를 구분해 검증 범위를 정립하였다.

Web의 API·DB·스크립트와 Chromium E2E 자동화 시험을 완료하였고, Host는 Web payload 계약 4건을 확인하였다. AI Server는 실시간 API 배치 검증과 라이브 v7 모델의 독립 홀드아웃 평가를 수행하였다. Host 4채널의 파일 크기별 평균 지연도 확인하였다. 다음 단계에서는 Windows 4채널 E2E와 CPU·RAM 사용률·P95 측정으로 통합 검증 범위를 확장한다.

5.2. 연구 성과

확인된 연구 성과는 다음 네 가지로 정리할 수 있다.

1. **다중 채널 처리 기반**: 클립보드, 웹메일, 클라우드 드라이브와 USB의 감지·분석·조치 코드와 공통 파일 추출 경로를 구현하였다. 조치 결과의 중앙 상태 세분화는 운영 확장 범위에 포함한다.
2. **문맥 재판정 파이프라인**: 정규식 후보를 KoELECTRA로 재판정하는 3단계 Colab API, 도메인 편향을 완화하도록 재구성한 데이터, v7 학습·하드 테스트 스크립트를 구성하였다.
3. **중앙 관제 기능**: Web 로그 수집, 중복 방지, 검색, 통계, 상세 근거와 위험 알림, Agent 인증을 구현하였다.

-
4. **구성 요소 연동 기반**: 동일한 event_id를 AI 요청·로컬 기록·Web 저장에 재사용하고 중앙에서 사건을 중복 없이 저장·조회할 수 있는 흐름을 구현하였다. 채널 매핑과 모델 버전 전달은 연동 계약 확장 범위에 포함한다.

이 구조는 단말 조치와 중앙 관제를 분리하면서 규칙 후보로 들어온 사건의 판정 근거를 같은 식별자로 추적할 수 있는 기반을 제공한다. 본 결과는 Windows 사용자 영역에서 하이브리드 탐지 절차와 중앙 관제를 구현·검증한 프로토타입으로서 의미가 있다. 계약 정합화, 실제 Windows E2E와 실제 기업 문서 기반 대규모 독립 모델 평가를 통해 한 컴퓨터의 반출 시도와 물리 조치를 다른 컴퓨터의 대시보드에서 검증하는 현장 적용 흐름으로 확장할 수 있다.

5.3. 향후 확장 방향

향후 연구는 다음 네 영역을 우선한다.

1. **계약 정합화**: Clipboard·Cloud Drive 채널 매핑, model_version 전달, allow 기록 범위와 실제 조치 결과 상태를 일치시킨다.
2. **모델 품질 확장**: 60건 규모의 독립 홀드아웃 평가를 완료하였으며, 향후 부서·문서 유형 단위 분할과 실제 기업 문서 기반 대규모 독립 평가를 진행한다.
3. **실장비 통합 및 성능 측정**: 실제 Windows 장비의 대상 채널과 다른 PC의 대시보드를 연결하고 CPU·RAM 사용률, P95와 중단 지연 재현성을 측정한다.
4. **운영 보안과 확장성**: Host-AI 인증과 민감 로그 축소, 개발용 비밀정보 교체, HTTPS 적용, DB 접근통제·백업·보존과 대용량 로그 구조를 확장한다.

6. 구성원별 역할 및 개발 일정

6.1. 역할 분담

구성원	주 담당	주요 수행 내용
박동화	AI Model	데이터셋 구성 · 도메인 편향 분석과 재설계, KoELECTRA v7 학습 · 검증 코드, 구어체 보강, 임계값 설정, AI 분석 서버와 시나리오 문서
김진우	Host Agent	Windows Agent 구조, Clipboard, Outlook · SMTP, Web Proxy, USB FileGuard, 파일 추출, 규칙-AI-조치 파이프라인과 Host 벤치마크
이상호	Web · 통합	FastAPI · SQLite, Dashboard/Logs UI, 검색 · 페이지 조회 · 위험 알림, 입력 검증 · 먹등 저장, 구성 요소 간 API 연동과 필드 정리 및 보고서 작성
전 구성원	공통	요구사항 · 아키텍처, JSON/REST 계약과 시연 시나리오 합의, 통합 조건 검토, 최종 보고서와 발표 준비

[표 6.1] 역할별 주요 수행 내용

6.2. 개발 일정 및 주요 산출물

시기	목표	주요 산출물
5월	문제 정의, 요구사항, 3계층 구조, 성능 목표와 역할 수립	3계층 구조, USB · 웹메일 · 클립보드 대표 시나리오와 초기 커널/API 후킹 설계
6월	Host 1단계 Clipboard	Host Agent와 Clipboard 초기 구현, 붙여넣기 억제 · 복원 구조 구체화
7월	메일 · 네트워크, AI 1차 모델, Web MVP	공통 AI payload · 파일 추출; AI OOD 특성 분석; FastAPI · SQLite · 상세 화면 구현
8월 10-19 일	USB · 웹메일과 구성 요소 연동	Web Mail MITM Proxy, USB FileGuard, Host-AI 데이터 계약, allow 복구, Cloud Drive 경로; Web 초기 구현
8월 15-26 일	AI 데이터 재학습과 임계값	AI 서버 · 학습 · 하드 테스트 반영, 구어체 40건 보강 v7, 0.20/0.41 설정과 로깅

표 6.2 (계속)

시기	목표	주요 산출물
8월 27-31 일	통합·안정화·최종 기능	Web의 위험 알림·인증·입력 검증·먹등 저장·페이지 조회 구현과 연동 필드 정리
9월	실제 통합, 성능 측정, 보고서· 발표	Host 4채널 평균 지연 벤치마크 반영; 계약 정합화· Windows 4채널 E2E·실제 기업 문서 기반 대규모 독립 평가·CPU/RAM 사용률·P95 확장 계획

[표 6.2] 2026년 개발 일정과 단계별 결과

작업	5월	6월	7월	8월	9월
요구사항·아키텍처					
Host Agent					
AI 데이터·모델					
Web Dashboard					
통합·검증·보고서					

[그림 6.1] 모듈별 개발 및 검증 일정

7. 참고문헌

- [1] J. Devlin, M.-W. Chang, K. Lee, and K. Toutanova, "BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding," *Proceedings of NAACL-HLT*, 2019.
- [2] K. Clark, M.-T. Luong, Q. V. Le, and C. D. Manning, "ELECTRA: Pre-training Text Encoders as Discriminators Rather Than Generators," *International Conference on Learning Representations*, 2020.
- [3] J. Park, "KoELECTRA: Pretrained ELECTRA Model for Korean," 2020.
<https://github.com/monologg/KoELECTRA>.
- [4] National Institute of Standards and Technology, *Security and Privacy Controls for Information Systems and Organizations*, NIST SP 800-53 Rev. 5, Update 1, 2020.
<https://doi.org/10.6028/NIST.SP.800-53r5>.